

AI AppSec Security Review



HADES BLACKWATCH

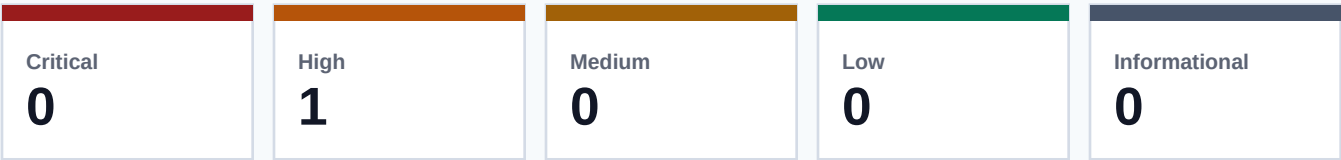
Internal - Version 0.1.0

Executive Summary

Target: Example AI Agent Platform

Date: 2026-05-12

Request changes: high-risk issues require remediation before approval.



Risk posture: Moderate. This report contains 1 normalized finding(s), ordered by severity and supported by local source review and generated evidence.

Scope and Authorization

ENVIRONMENT

local/staging

ACCESS LEVEL

source + imported scanner evidence

AUTHORIZED

True

INCLUDED

```
[
  "LLM prompt flow",
  "MCP tool manifest",
  "Agent web fetch tool",
  "Scanner finding import"
]
```

EXCLUDED

```
[
  "Production active scanning",
  "Credentialed cloud posture review"
]
```

Methodology

FRAMEWORKS

```
[
  "OWASP LLM Top 10",
  "OWASP Agentic Top 10",
  "OWASP AIVSS",
  "MITRE ATLAS",
  "NIST AI RMF GenAI Profile"
]
```

AGENTS USED

```
[
  "Security Orchestrator",
  "Latest Threat Intel",
  "MCP Server Auditor",
  "Secure Code Review",
  "Finding Correlator",
  "Report"
]
```

SCANNER BACKENDS

```
[
  "SonarQube imported evidence"
]
```

MCP POLICY

Escalation-only; local evidence and imported reports were preferred.

Skill Coverage and Specialist Notes

This review used a focused subset of specialists because the input combined source review with imported scanner evidence.

Security Orchestrator

Status: Used

Focus: Scope, authorization, severity, and final verdict

Coverage: Confirmed local/staging scope and avoided live scanner or MCP actions.

Latest Threat Intel Agent

Status: Used

Focus: Per-finding threat context and source freshness

Coverage: Added source-linked threat intel for the SSRF/tool-abuse finding.

MCP Server Auditor

Status: Used

Focus: Tool boundary and least-privilege review

Coverage: Reviewed the agent fetch tool as an MCP-adjacent privileged action.

Report Agent

Status: Used

Focus: Detailed HTML/PDF deliverable

Coverage: Converted the normalized finding into a findings-first report with fixes and tests.

Threat Intelligence

As of: 2026-05-28

The current threat context for agentic systems emphasizes prompt injection reaching tools, excessive agency, MCP authorization boundaries, SSRF controls, and traceable governance evidence.

Prompt injection to privileged tools

Why it matters: OWASP LLM 2025 keeps prompt injection and excessive agency in scope for GenAI apps, and the reviewed issue allows model-influenced URLs to reach a network-capable tool.

Recommended action: Enforce deterministic URL validation, egress controls, approval gates, and logging outside the model.

Linked findings: F-SSRF-001

MCP SSRF and token boundary risk

Why it matters: MCP security guidance calls out SSRF, token passthrough, scope minimization, and authorization validation as key implementation risks.

Recommended action: Bind tokens to intended audiences, avoid token passthrough, minimize scopes, and block private or reserved IP ranges before outbound requests.

Linked findings: F-SSRF-001

Threat Intel Sources

OWASP Top 10 for LLM and GenAI Apps 2025 - <https://genai.owasp.org/llm-top-10/> - Prompt injection, excessive agency, sensitive information disclosure, and vector/embedding weaknesses.

Model Context Protocol Security Best Practices -

https://modelcontextprotocol.io/docs/tutorials/security/security_best_practices - MCP SSRF, token passthrough, authorization, local server compromise, and scope minimization guidance.

Personalized Recommendations

These actions are tailored to Example AI Agent Platform, the authorization model, actual evidence sources, and the current finding set.

High

Put the fetch tool behind a shared URL policy gate before letting the agent planner choose destinations.

Why: The example platform gives the model a network-capable action, so prompt injection can become SSRF unless policy enforcement happens outside the LLM.

Owner: Agent platform / MCP owner

Timeframe: 0-7 days

Linked findings: F-SSRF-001

Findings Index

High	F-SSRF-001: Agent web fetch tool can receive model-controlled URLs
------	--

1. Agent web fetch tool can receive model-controlled URLs

Confidence: high

Affected component: agent web fetch tool

Affected file: src/tools/fetch_url.ts

Affected endpoint: /api/agent/tools/fetch-url

Affected asset: internal network reachable by agent runtime

Evidence

```
{
  "summary": "The fetch tool accepts an arbitrary URL from the agent planner without a deterministic host allowlist or private IP block.",
  "rule_id": "custom-ai-ssrf"
}
```

Attack Path

A prompt injection causes the model to call the fetch tool with an internal metadata or service URL. The tool performs the request from the trusted runtime.

AI / Agent Relevance

The LLM is not a trusted policy enforcement point. Prompt or RAG injection can influence tool parameters unless deterministic validation exists before network access.

Threat Intelligence

```

{
  "as_of": "2026-05-28",
  "summary": "This finding maps to a common agentic exploit pattern: prompt injection or compromised context influences a network-capable tool, turning an AI workflow into an SSRF path.",
  "sources": [
    {
      "name": "OWASP Top 10 for LLM and GenAI Apps 2025",
      "url": "https://genai.owasp.org/llm-top-10/",
      "relevance": "Prompt injection and excessive agency are directly relevant to model-influenced tool parameters."
    },
    {
      "name": "Model Context Protocol Security Best Practices",
      "url": "https://modelcontextprotocol.io/docs/tutorials/security/security_best_practices",
      "relevance": "MCP guidance highlights SSRF and least-privilege controls for tool-connected AI systems."
    },
    {
      "name": "MITRE ATLAS",
      "url": "https://atlas.mitre.org/",
      "relevance": "Use ATLAS to map AI-specific adversary behavior around prompt injection and tool abuse."
    }
  ],
  "signals": [
    {
      "theme": "Prompt injection to tool abuse",
      "relevance": "The vulnerable tool trusts model-selected URLs rather than a deterministic network policy.",
      "recommended_action": "Block private and link-local ranges after DNS resolution, require allowlists, and log denied attempts."
    }
  ],
  "mapped_techniques": {
    "mitre_atlas": "Prompt injection and tool abuse pattern",
    "cwe": "CWE-918"
  },
  "detection_or_test": "Add a regression test that attempts metadata-service and RFC1918 URLs through the agent tool and asserts denial before outbound network access.",
  "freshness": "Checked against official sources on 2026-05-28",
  "confidence": "High"
}

```

Framework Mappings

```
{
  "owasp_llm": "LLM01 Prompt Injection; LLM06 Excessive Agency",
  "owasp_agentic": "Tool Misuse; Excessive Agency",
  "mitre_atlas": "Prompt Injection / Tool Abuse",
  "nist_ai_rmf": "Map, Measure, Manage",
  "cwe": "CWE-918",
  "cve": null
}
```

Score

```
{
  "system": "AIVSS",
  "value": "High",
  "rationale": "High autonomy, privileged network position, reproducible attack path, and weak deterministic control."
}
```

Recommended Fix

Add an outbound host allowlist, block private/link-local IP ranges after DNS resolution, require explicit approval for untrusted domains, and log denied attempts.

Regression Test

Add an integration test that attempts to fetch `http://169.254.169.254` and internal RFC1918 ranges through the agent tool and asserts denial before any network request.

Residual Risk

Residual risk remains if newly added tools bypass the shared URL validation library.

Attack Path Visualization

The risk is not that the model is malicious by itself. The risk is that untrusted prompt or retrieved context can steer a network-capable tool unless deterministic URL policy checks happen outside the model.

1. Prompt Influence: Untrusted content influences the agent planner.

Control gap: The prompt is treated as trusted instruction.

Defensive breakpoint: [Classify external prompt and retrieved content as untrusted.](#)

2. Tool Selection: The planner selects the web fetch tool with a model-controlled destination.

Control gap: Tool parameters rely on model judgment.

Defensive breakpoint: [Validate tool parameters before execution.](#)

3. Network Boundary: The runtime attempts outbound access from a trusted network position.

Control gap: No allowlist or private IP block after DNS resolution.

Defensive breakpoint: [Block private, reserved, and link-local ranges.](#)

4. Impact: Internal services or metadata endpoints may become reachable through the agent.

Control gap: Runtime egress is too broad.

Defensive breakpoint: [Restrict egress and require approval for new domains.](#)

5. Detect / Break: Denied URL attempts should be logged and covered by regression tests.

Control gap: No test proves the unsafe request is blocked.

Defensive breakpoint: [Add CI tests and runtime detections for blocked destinations.](#)

Attacker goal: Cause the agent runtime to request an internal or otherwise unauthorized URL.

Preconditions: The attacker can influence prompt, chat, document, or workflow context that reaches the agent planner.

Control breaks: Missing deterministic URL policy enforcement outside the LLM.

Impact: Internal network reachable by the agent runtime.

Detection points: Denied requests to private, reserved, link-local, and metadata ranges.

Defensive breakpoints: URL allowlist, DNS resolution checks, egress restriction, approvals, logging, and regression tests.

Safety note: No payloads or unauthorized exploitation steps are provided.

Personalized Remediation Roadmap

F-SSRF-001

Add an outbound host allowlist, block private/link-local IP ranges after DNS resolution, require explicit approval for untrusted domains, and log denied attempts.

Regression Test Plan

F-SSRF-001

Add an integration test that attempts to fetch `http://169.254.169.254` and internal RFC1918 ranges through the agent tool and asserts denial before any network request.

Residual Risk and Assumptions

Residual risk depends on complete remediation, regression test adoption, scanner coverage, evidence redaction, and continued enforcement of deterministic authorization around model-driven actions.

Overall verdict: Request changes: high-risk issues require remediation before approval.

Report title: AI AppSec Security Review